

CompTIA SecAI+ Certification

Section 5 – AI Attack Vectors and Defense

Official Study Notes (Downloadable)

Section Overview

Section 5 is the **most heavily weighted and most critical section** of the CompTIA SecAI+ exam. It focuses on how AI systems are attacked, abused, manipulated, and exploited—and how defenders detect, mitigate, and recover from these threats.

This section demands **scenario-based reasoning**. You are not only expected to recognize attack types, but also to choose the *most appropriate defensive response* based on risk, impact, and operational constraints.

This section prepares you to:

- Identify AI-specific attack vectors
- Understand how attacks unfold across the AI lifecycle
- Select effective mitigations and compensating controls
- Think like both an attacker and a defender

AI-Specific Threat Landscape

AI systems introduce new attack surfaces beyond traditional IT systems.

Unique characteristics attackers exploit:

- Dependence on data quality
- Model opacity and complexity
- Probabilistic outputs
- Continuous learning behavior

Attackers often target **inputs, models, outputs, or supply chains** rather than infrastructure alone.

Data Poisoning Attacks

Data poisoning involves manipulating training or operational data to influence model behavior.

Attack methods:

- Injecting malicious samples into training data
- Biasing datasets toward attacker goals
- Corrupting data labels

Impact:

- Reduced model accuracy
- Biased or unsafe decisions
- Loss of trust in AI outputs

Defenses:

- Data validation
- Source verification
- Data integrity monitoring
- Controlled training pipelines

Model Poisoning and Backdoor Attacks

Model poisoning targets the model itself rather than raw data.

Characteristics: - Hidden triggers embedded during training - Malicious behavior activated under specific conditions

Risk: - Normal behavior during testing - Malicious behavior in production

Mitigations: - Secure training environments - Model testing under adversarial conditions - Version control and integrity checks

Adversarial Input Attacks

Adversarial attacks involve crafting inputs that deceive models while appearing benign to humans.

Examples: - Slightly modified images - Manipulated text prompts - Obfuscated malware samples

Security implications: - Bypassed detection - False negatives

Defensive strategies: - Adversarial training - Input normalization - Ensemble models

Prompt Injection Attacks

Prompt injection manipulates language models by embedding malicious instructions.

Attack goals: - Override system behavior - Extract sensitive data - Generate harmful outputs

Defenses: - Prompt isolation - Input sanitization - Output validation - Least-privilege model design

Prompt injection is one of the most common LLM attack vectors.

Model Inversion Attacks

Model inversion attempts to reconstruct sensitive training data from model outputs.

Target data: - Personal data - Proprietary information

Defensive controls: - Output limitation - Differential privacy - Monitoring inference queries

Membership Inference Attacks

Membership inference determines whether a specific data point was used during training.

Risk: - Privacy violations - Regulatory non-compliance

Mitigations: - Regularization - Privacy-preserving training - Access controls on inference APIs

Model Extraction and Theft

Model extraction attacks attempt to steal model functionality via repeated queries.

Threat impact: - Loss of intellectual property - Competitive disadvantage

Defenses: - Rate limiting - Query monitoring - Watermarking

Supply Chain Attacks on AI Systems

AI supply chains include: - Training datasets - Pretrained models - Libraries and dependencies

Attack vectors: - Compromised datasets - Malicious pretrained models - Insecure dependencies

Mitigation: - Trusted sources - Artifact verification - Dependency scanning

Evasion Attacks

Evasion attacks manipulate inputs at inference time.

Common techniques: - Obfuscation - Timing manipulation - Adaptive probing

Defense: - Behavioral monitoring - Model diversity - Continuous evaluation

AI-Enabled Attacks

Attackers use AI to: - Generate phishing content - Automate reconnaissance - Scale malware development

Security implication: Attack velocity and sophistication increase dramatically.

Defensive Controls and Compensating Measures

Effective defense requires layered controls.

Control categories: - Preventive (input validation) - Detective (monitoring and logging) - Corrective (model rollback)

Defense-in-depth is essential.

Red Teaming and Adversarial Testing

Proactive testing improves resilience.

Approaches: - Adversarial simulations - Prompt stress testing - Model abuse scenarios

Testing should occur before and after deployment.

Incident Response for AI Attacks

AI-specific incident response includes: - Model isolation - Data pipeline inspection - Output review - Retraining or rollback

Response plans must include AI-specific actions.

Exam Keywords to Watch For

- Data poisoning
 - Adversarial input
 - Prompt injection
 - Model extraction
 - Membership inference
 - Compensating control
 - Defense-in-depth
-

Rapid Revision Summary

- AI attacks target data, models, and outputs
- Prompt injection is a dominant LLM risk
- Data poisoning undermines trust
- Model theft threatens IP

- Layered defenses are required
 - Testing and monitoring are critical
-

End of Section 5 – Study Notes